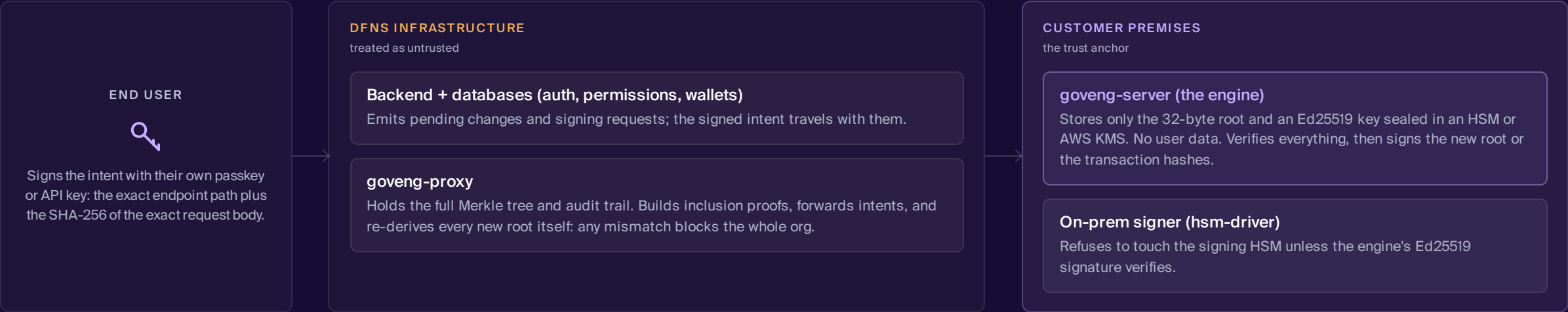


Nothing changes, and nothing gets signed, without proof

The customer's engine keeps one 32-byte Merkle root. Every operation must prove itself against it.



User action: one signature covers one exact request; it cannot be replayed or repointed.

Proofs in: signed intent + Merkle proofs over mTLS. The engine dials out, so the customer opens no inbound port.

Signatures out: signed root (entity changes) or signed hashes (transactions), verified downstream.

WHAT THE ENGINE VERIFIES, IN ORDER, BEFORE SIGNING ANYTHING

- 1 · inclusion

Signer is in the tree

Merkle proofs for the signing user and credential against the engine's own root. The public key is read from the proven leaf, never from the request.
- 2 · intent

Signature and binding

Verifies the passkey signature, then that the challenge commits to the exact path and payload hash. Tampered bodies fail closed.
- 3 · authorization

Signer holds the right

An in-tree chain (assignment → permission → operation set) must grant every operation the route requires. Unmapped routes fail closed.
- 4 · rules

Business invariants

Active user and credential, identity bound to the signed payload, and a credCounter that rejects credentials injected outside registration.
- 5 · rollback

State only advances

Monotonic root and data-model versions, two-phase ceremonies, stale-restore alarms, and replication to a backup that never regresses.

Result: even with DFNS fully compromised, governed data cannot be forged, altered or rolled back silently. **No valid user signature, no state change, no transaction signature.**

Identity and permissions are proven; policies are still trusted

Transaction signing is hard-blocked by the engine; the governed tree is what that gate checks against; policies are not covered yet.

BLOCKED IF THE ENGINE REFUSES

Transaction signing

The strongest guarantee: the engine sits in the signing path itself.

- **The on-prem signer will not use the blockchain key** without the engine's signature: no engine approval, no transaction. Ever.
- **Before co-signing**, the engine proves the signer and credential are in the tree, active, and permissioned for the route.
- **Deactivated or unproven identities** can never obtain a signature.

Coming next: the engine will also verify that each signed hash matches the exact transaction the user approved.

GOVERNED IN THE SIGNED TREE

Authentication & permissions

Five datasets become Merkle leaves, each frozen to an exact field list (below).

- **Every mutation** needs a user-signed intent plus a Merkle proof, then a new engine-signed root.
- **Authorization is re-enforced:** the engine replays the backend's permission check against governed leaves only.
- **Deletes and archives** are governed too: revoking an assignment is a proven leaf removal, never a silent drop.

This tree is what the signing gate checks. An identity or permission DFNS cannot prove in the tree never reaches a blockchain key.

NOT GOVERNED YET

Policies & predicates

Enforced by the DFNS backend only. No leaf, no tamper evidence.

- **Policy definitions, approvals and quorums** live outside the tree; the engine does not evaluate them yet.
- **Permission predicates** (amount caps, time windows) are deferred while their data model settles.
- **Also out:** orgs, resource ownerships, SSO settings, token hashes.

Roadmap: policy governance (definitions, then approval verification) is the next phase of the integrity framework.

GOVERNED FIELDS, FROZEN PER DATA MODEL

users

id, orgId, kind, email, username, registrationCode, registrationCodeExpirationDate, isActive, isArchived, externalId, isServiceAccount, + credCounter (engine-injected)

credentials

credUuid, kind, credData, userId, isActive, origin, relyingPartyId

permissions

id, orgId, name, status, isImmutable, isArchived, operationSetId, kind

operation sets

id, orgId, name, operations

assignments

id, permissionId, identityId, isImmutable, isArchived

Permissions prove **who may do what**. Predicates and policies decide **under which conditions**. Today the engine proves the former and trusts DFNS for the latter: that is the roadmap boundary.